

Susan Shepard

Boston, MA | [LinkedIn](#) | HireSusanShepard@pm.me

SUMMARY

GRC Engineering Club Boston Chapter President | Cyber Risk Quantification | AI-Driven Security Automation

GRC engineer who builds the platforms that scale compliance, architecting full-stack systems (React, Node.js/Express, PostgreSQL) that automate evidence collection, multi-framework compliance mapping, and quantitative risk scoring. Partners with product and engineering teams to embed AI into GRC workflows and translate technical risk into board-level decisions.

WORK EXPERIENCE

Rapid7

Boston, MA

Staff - Trust, Risk, and Compliance Analyst - Information Security

Feb 2026 - Present

Lead Security Risk Analyst

Feb 2023 - Feb 2026

Lead Security Compliance Analyst

Sep 2021 - Feb 2023

- Architected and engineered InsightGRC, an autonomous GRC and continuous control monitoring platform (React/Vite, Node.js/Express, PostgreSQL on Cloud SQL) — automating evidence collection, multi-framework compliance mapping, third-party risk assessment, and executive audit reporting end to end.
- Built automated import engines, data models, and crosswalk parsers mapping 15+ frameworks — NIST SP 800-53 r5, ISO 27001/27017, PCI-DSS, FedRAMP, GovRAMP, TxRAMP, DORA, NIS2, Cyber Essentials, CSA CCM/CAIQ, and OSCAL — eliminating duplicate framework-by-framework compliance work.
- Developed a Node.js/Slack Bolt evidence-automation pipeline pulling continuous control evidence from GCP infrastructure, IdPs, EDRs, Google Drive, and ticketing systems (Jira/Freshservice), plus two-way OneTrust sync scripts automating treatment kickoffs and vendor assessments.
- Built an AI Evidence Scout and automated rubric assessors that validate evidence sufficiency and score control health, and integrated a FAIR-based risk quantification model into an LLM application for automated, contextual risk scoring at scale — one of Rapid7's first production AI/GRC integrations.
- Authored a Manifest V3 Chrome extension (cra-portal-assistant) automating customer risk assessment questionnaire fulfillment across vendor portals (Archer, OneTrust, Ombud), and built SCRM and vendor-intake workspaces for third-party risk profiling — cutting CRA response SLAs from weeks to days.
- Designed PostgreSQL schemas with immutable audit logging and dual-write state tracking underpinning audit workspaces (sample selection, finding lifecycle, board-level reporting) and automated User Access Review campaigns with attestation tracking and least-privilege remediation.
- Architected Rapid7's first Integrated IS Risk Management Framework (ISIRM) and founded its first annual Security Risk Assessment, establishing a recurring board-visibility cadence.
- Built the Incident Severity Calculator (OWASP + EO-14028 legal materiality) and Findings Management Calculator, standardizing cyber-event classification and cutting triage time 40%; led Rapid7's SEC Cyber Incident Disclosure program and directed audit readiness to 100% evidence submission with zero findings.

Seven Bridges, Inc.

Boston, MA

Senior Risk and Compliance Analyst

Mar 2020 - Sep 2021

- Managed 650+ vendors and executed audits for HIPAA, ISO, NIST, SOC, and FedRAMP compliance.
- Negotiated and reviewed security and privacy contracts (BAA, ISA, MSA), directly enabling \$1.5M+ in quarterly bookings.
- Drove 14+ audit assurance activities, strengthening compliance posture across security and privacy frameworks.

Acquia, Inc.

Boston, MA

Senior Information Security Analyst

Nov 2019 - Mar 2020

Senior Risk and Controls Analyst, Information Security

Aug 2018 - Mar 2019

Risk and Controls Analyst, Information Security

Nov 2017 - Aug 2018

- Designed and implemented a global GDPR compliance program (policies, vendor due diligence, lawful processing, breach response, training).
- Managed 900+ vendors with audits against HIPAA, ISO, NIST, SOC, and FedRAMP standards.
- Delivered enterprise-wide audit readiness across security and privacy standards.

Nuance Communications, Inc. Burlington, MA

Healthcare IT GRC Analyst, Information Security

Jan 2017 - Nov 2017

- Built formal security and privacy GRC program for healthcare division, aligned to HIPAA, HITRUST, ISO, NIST, and SOC2.
- Reviewed security and privacy contracts, enabling \$1.2M+ in quarterly compliant revenue.

iRobot, Bedford, MA

Program Coordinator - Information Security, Intern

May 2016 - Jan 2017

Veritas (Formerly: Symantec)

Backup and Recovery Testing Engineer - Intern

Nov 2015 - May 2016

EDUCATION

Boston University

Boston, MA

M.S. Computer Information Systems – Concentration: Security

University of Massachusetts - Lowell

Lowell, MA

B.S. Information Technology — magna cum laude

PROFESSIONAL CERTIFICATIONS

- **Certified Information Security Manager (“CISM”)** – ISACA
- **Certified in Risk and Information Systems Control (“CRISC”)** – ISACA
- **Advanced in AI Security Management (“AAISM”)** – ISACA
- **Advanced in AI Risk (“AAIR”)** – ISACA
- **Certified in Cybersecurity (“CC”)** – ISC2
- **AWS Certified Cloud Practitioner (“CLF-C02”)** – AWS

SKILLS and INTERESTS

Skills

- **Risk & Compliance:** Security Risk Management, FAIR Risk Quantification, CVSS, OWASP, GDPR, HIPAA, ISO 27001, NIST CSF, SOC 2/3, FedRAMP, HITRUST, EO-14028 Materiality Analysis
- **AI & Automation:** LLM integration for automated risk scoring, prompt engineering, agentic workflow development, RAG-based GRC tooling
- **GRC Platforms:** OneTrust, Archer, ServiceNow GRC, AuditBoard
- **Programming & Tools:** Python (automation, data analysis), SQL (querying), Excel (advanced modeling & macros)
- **Cloud Security:** AWS, cloud risk assessment and controls, cloud GRC platform architecture

Interests

- Home-lab AI/LLM and agentic AI experimentation applied to risk, GRC, and security workflows
- Building and automating risk quantification calculators and dashboards
- Experimenting with RAG-based AI tooling for security risk governance and privacy compliance

LEADERSHIP and CONTRIBUTIONS

Publications

- **ISC² Technical Guidance Paper Co-Author and Subject Matter Expert**
- **Medium Article - *Hari Seldon Would’ve Made a Great CISO: What Cyber Risk Analysts Can Learn From Asimov’s Foundation***

Volunteering

- **GRC Engineering Club** – President, Boston Chapter
- **ISACA AAISM Beta Testing** – Beta Tester
- **ISACA AAISM Exam Writing Development Group** – Exam Writer
- **Mentoring:** Big Brother Big Sister (BBBS), ISACA, and Boston University Admissions